Northwind Financial

NIST Cybersecurity Framework 2.0
Cybersecurity Maturity Assessment

ASSESSMENT DATE
August 2026

OVERALL MATURITY
Tier 1 · CMMI 1.95

FUNCTIONS ASSESSED
6 of 6

Executive Summary

Overall maturity: Tier 1 (average CMMI 1.95) across 6 of 6 Functions assessed

Northwind Financial manages cybersecurity through defined executive accountability structures and an established continuous monitoring capability supported by a managed security operations partner. Strongest practice sits within the Detect function, where multi-source telemetry and fast event triage provide robust operational visibility across core banking platforms, backed by clear statutory governance under the Senior Managers and Certification Regime. However, overall maturity reflects substantial operational gaps across the Protect, Respond, and Recover functions. While threat identification is rapid, the organisation currently lacks formalised incident response playbooks, structured business recovery workflows, and comprehensive workforce training to contain and resolve major incidents. Establishing enterprise-wide asset inventories, formalising containment and recovery procedures, and standardising identity controls represent the most impactful opportunities to enhance operational resilience.

GOVERN

Sets the strategy, policy, and accountability for how the organisation manages cyber risk.

Executive accountability is clearly established under formal regulatory management frameworks, supported by quarterly Board reporting and structured vendor oversight policies. Defining explicit risk appetite statements and replacing informal email-based mission communication with standardized risk governance remain the leading opportunities.

IDENTIFY

Understanding what needs protecting — the organisation's systems, data, and the risks to them.

Vulnerability scanning routines and third-party risk tracking provide foundational visibility across critical banking suppliers. Developing centralised inventories of hardware, software, and data assets alongside a standardized risk calculation methodology is the necessary next step.

PROTECT

The safeguards — access control, encryption, training — that limit or contain a cyber incident.

Dedicated security controls safeguard software development and privileged administrative access, supported by segregation between testing and production environments. Expanding safeguards to include structured workforce training, data-at-rest encryption, and formalised hardware lifecycle management will address key vulnerabilities.

DETECT

The organisation's ability to notice that a cybersecurity incident is happening.

A specialised external operations centre delivers robust, metric-driven log correlation and rapid adverse event triage across network and endpoint environments. Extending real-time visibility into physical locations and external cloud software providers will close remaining visibility gaps.

RESPOND

The actions taken to contain and manage a cybersecurity incident once confirmed.

Initial alert triage and operational escalation paths function reliably through the managed security partnership. Documenting formal internal incident response playbooks, root-cause investigation procedures, and clear containment protocols is required to coordinate major crisis handling effectively.

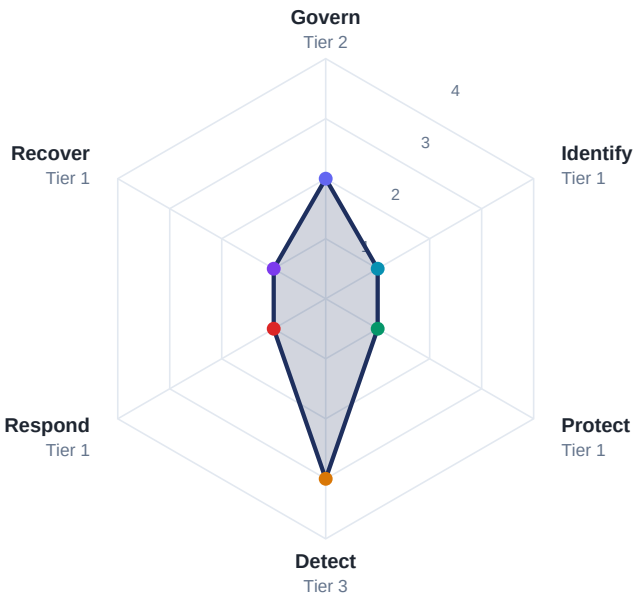
RECOVER

Restoring normal business operations and services after a cybersecurity incident.

Annual disaster recovery exercises provide a basic baseline for technical platform availability. Establishing documented operational recovery playbooks, system restoration prioritisation, and coordinated stakeholder communication templates will ensure rapid operational resumption following severe disruptions.

Results Overview

Maturity by Function on the NIST CSF Tier scale (1-4), with the underlying CMMI score (1-5) for every Category and Subcategory assessed.



Overall maturity	Tier 1	CMMI 1.95
Govern	Tier 2	CMMI 2.67
Identify	Tier 1	CMMI 1.67
Protect	Tier 1	CMMI 1.60
Detect	Tier 3	CMMI 3.50
Respond	Tier 1	CMMI 1.25
Recover	Tier 1	CMMI 1.00

Assessment scoring — CMMI by Function, Category and Subcategory

GOVERN	
GV.OC	2
GV.OC-01	1
GV.OC-02	2
GV.OC-03	2
GV.OC-04	3
GV.OC-05	2
GV.RM	2
GV.RM-01	2
GV.RM-02	2
GV.RM-03	3
GV.RM-04	2
GV.RM-05	3
GV.RM-06	2
GV.RM-07	1
GV.RR	3
GV.RR-01	4
GV.RR-02	4
GV.RR-03	3
GV.RR-04	2
GV.PO	3
GV.PO-01	2
GV.PO-02	3
GV.OV	3
GV.OV-01	3
GV.OV-02	3
GV.OV-03	3
GV.SC	3
GV.SC-01	3
GV.SC-02	3
GV.SC-03	3
GV.SC-04	3
GV.SC-05	3
GV.SC-06	3
GV.SC-07	3
GV.SC-08	1
GV.SC-09	3
GV.SC-10	1

IDENTIFY	
ID.AM	1
ID.AM-01	1
ID.AM-02	1
ID.AM-03	1
ID.AM-04	2
ID.AM-05	1
ID.AM-07	1
ID.AM-08	1
ID.RA	2
ID.RA-01	3
ID.RA-02	2
ID.RA-03	2
ID.RA-04	2
ID.RA-05	2
ID.RA-06	2
ID.RA-07	3
ID.RA-08	1
ID.RA-09	2
ID.RA-10	3
ID.IM	2
ID.IM-01	2
ID.IM-02	2
ID.IM-03	3
ID.IM-04	2

PROTECT	
PR.AA	2
PR.AA-01	2
PR.AA-02	1
PR.AA-03	2
PR.AA-04	1
PR.AA-05	2
PR.AA-06	1
PR.AT	1
PR.AT-01	1
PR.AT-02	1
PR.DS	1
PR.DS-01	1
PR.DS-02	2
PR.DS-10	1
PR.DS-11	1
PR.PS	2
PR.PS-01	1
PR.PS-02	1
PR.PS-03	1
PR.PS-04	3
PR.PS-05	1
PR.PS-06	3
PR.IR	2
PR.IR-01	2
PR.IR-02	1
PR.IR-03	2
PR.IR-04	1

DETECT	
DE.CM	3
DE.CM-01	4
DE.CM-02	1
DE.CM-03	4
DE.CM-06	2
DE.CM-09	4
DE.AE	4
DE.AE-02	4
DE.AE-03	4
DE.AE-04	3
DE.AE-06	4
DE.AE-07	3
DE.AE-08	4

RESPOND	
RS.MA	2
RS.MA-01	2
RS.MA-02	3
RS.MA-03	2
RS.MA-04	2
RS.MA-05	1
RS.AN	1
RS.AN-03	1
RS.AN-06	1
RS.AN-07	2
RS.AN-08	1
RS.CO	1
RS.CO-02	1
RS.CO-03	1
RS.MI	1
RS.MI-01	1
RS.MI-02	1

RECOVER	
RC.RP	1
RC.RP-01	1
RC.RP-02	1
RC.RP-03	1
RC.RP-04	1
RC.RP-05	1
RC.RP-06	1
RC.CO	1
RC.CO-03	1
RC.CO-04	1

Areas of Improvement

The themes running through this assessment's findings, most material first.

01

Incident recovery and crisis communication readiness

Northwind Financial currently lacks documented procedures, prioritisation criteria, and approved message templates for restoring services during a major operational incident. Without pre-established recovery playbooks and external notification protocols, a significant outage risks prolonged operational downtime, regulatory scrutiny, and customer disruption. Defining structured restoration playbooks and stakeholder communication channels will safeguard commercial continuity and client trust.

Grounded in: RC.RP-01, RC.RP-02, RC.CO-03, RC.CO-04

02

Workforce cybersecurity awareness and role-based training

There is no structured security education curriculum, mandatory completion tracking, or specialised training programme for staff handling sensitive operations. Relying on an annual staff survey leaves personnel unprepared to detect and resist sophisticated social engineering attempts or handle operational cyber risks. Implementing regular, role-specific training programmes builds an effective human line of defence across the business.

Grounded in: PR.AT-01, PR.AT-02

03

Identity verification and platform hygiene controls

Protocols for verifying employee identities during onboarding, standardising single sign-on assertions, preventing unauthorised software, and retiring obsolete hardware are not formalised. Gaps in credential management and hardware lifecycle planning increase exposure to unauthorized platform access and unpatched system vulnerabilities. Introducing unified identity verification standards and baseline device controls will systematically eliminate common entry points for attackers.

Grounded in: PR.AA-02, PR.AA-04, PR.PS-03, PR.PS-05

04

Physical facility access management and monitoring

The organisation does not maintain centralised monitoring or formalised access policies for its physical operating facilities. Physical security gaps leave local computing environments and network interfaces vulnerable to unrecorded physical access or tampering. Integrating physical access management with centralised corporate monitoring ensures consistent security across all operational locations.

Grounded in: PR.AA-06, DE.CM-02

05

Strategic risk context and external vulnerability intake

Cybersecurity decision-making is disconnected from broader commercial objectives, strategic opportunities, and public vulnerability reporting channels. Without a formal vulnerability disclosure process or explicit risk appetite statements, the organisation cannot systematically capture external security intelligence or align technology investments with business strategy. Formalising external reporting pathways and integrating risk context into commercial planning will ensure balanced and proactive risk management.

Grounded in: GV.OC-01, GV.RM-07, ID.RA-08

Detailed Findings

Every Subcategory assessed, by Function and Category. Confidence below 60% means the evidence provided was too thin to score reliably.

GOVERN · TIER 2

GV.OC — Organizational Context

confidence 85%

CMMI 2

The organization demonstrates a fragmented approach to organizational context (CMMI Level 2). While critical business services are formally managed under an Operational Resilience Policy and regulatory requirements are tracked via the SM&CR framework, communication of the business mission remains highly informal (via email), and external dependencies are managed in silos rather than a consolidated register.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
GV.OC-01 — The organizational mission is understood and informs cybersecurity risk management	1	partial	90%	The organization's mission and business strategy are communicated informally to cybersecurity risk decision-makers via an email from the CISO's manager, Jeff.	There is no formal, documented risk context statement or security strategy that systematically links the organizational mission to cybersecurity risk decisions.	Formally document the organizational mission and business strategy in a security strategy document, and establish a structured process to share this with cybersecurity decision-makers.
GV.OC-02 — Internal and external stakeholders are understood, and their needs and expectations regarding cybersecurity risk management are understood and considered	2	partial	80%	The organization identifies key stakeholders such as regulators (PRA-FCA) and the Board Risk Committee, with responsibilities defined under the SM&CR framework, but stakeholder expectations are managed in a fragmented manner across different roles.	The organization lacks a consolidated, organization-wide registry that formally maps all internal and external stakeholders and their specific cybersecurity expectations.	Develop a comprehensive stakeholder registry that documents the cybersecurity expectations of all key internal and external stakeholders and integrate this into the GRC framework.
GV.OC-03 — Legal, regulatory, and contractual requirements regarding cybersecurity — including privacy and civil liberties obligations — are understood and managed	2	partial	85%	The organization tracks regulatory requirements like the PRA Rulebook and SM&CR, and manages supplier contractual requirements through the Vendor Risk Management Policy, split between the Compliance Officer and the CISO.	The organization lacks a centralized compliance register that maps all legal, regulatory, and contractual requirements directly to specific cybersecurity controls and risk decisions.	Establish a centralized legal and regulatory compliance register owned by the GRC or Compliance function that maps all applicable requirements directly to the organization's cybersecurity policies.
GV.OC-04 — Critical objectives, capabilities, and services that stakeholders depend on or expect from the organization are understood and communicated	3	present	85%	The CISO and Operations Business Unit Head jointly own the technology resilience elements of the Group's important business services under the formal Operational Resilience Policy, aligned with the PRA Rulebook.	While important business services are formally identified, specific cybersecurity resilience objectives (such as RTOs and RPOs) are not systematically communicated and integrated into broader cybersecurity risk decisions.	Define and document specific cybersecurity resilience objectives for each important business service, and ensure these are formally reviewed and updated on a defined cadence.
GV.OC-05 — Outcomes, capabilities, and services that the organization depends on are understood and communicated	2	partial	80%	The organization identifies key external dependencies, such as the SaaS general insurance platform vendor and Critical-tier suppliers, and manages them through the Vendor Risk Management Policy and Logging and Monitoring Standard.	There is no consolidated, organization-wide inventory of all critical external dependencies mapped directly to the business services they support.	Create a centralized external dependency register that maps all critical third-party services, SaaS platforms, and infrastructure providers to the specific business capabilities they support.

GOVERN · TIER 2

GV.RM — Risk Management Strategy

confidence 85%

CMMI 2

Northwind Financial has established basic governance structures, including a Group Risk Management Strategy and quarterly reporting to the Board Risk Committee by the CISO. However, the organization lacks formalized, cybersecurity-specific risk appetite and tolerance statements, and communication of strategic context is currently ad-hoc via email. Standardized risk calculation is limited to CVSS-based vulnerability prioritization, and positive risks are not characterized or discussed.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
GV.RM-01 — Risk management objectives are established and agreed to by organizational stakeholders	2	partial	85%	The CISO is responsible for the Group Risk Management Strategy and reports the cyber risk posture to the Board Risk Committee. However, communication of the mission and business strategy to risk decision-makers is currently limited to an email from the CISO's boss.	There is no evidence of formal, documented, and measurable cybersecurity risk management objectives that are agreed upon by senior leaders and used to measure risk performance.	Formally document near-term and long-term cybersecurity risk management objectives as part of the annual strategic planning process, and obtain formal agreement from senior leadership.
GV.RM-02 — Risk appetite and risk tolerance statements are established, communicated, and maintained	2	partial	85%	The CISO is responsible for the Group Risk Management Strategy, but there is no explicit mention of documented cybersecurity risk appetite or tolerance statements.	The organization lacks documented, cybersecurity-specific risk appetite and tolerance statements that are communicated to stakeholders.	Develop and document explicit cybersecurity risk appetite and tolerance statements, translating them into specific, measurable thresholds (e.g., acceptable downtime or data exposure classes) and communicate them across the organization.
GV.RM-03 — Cybersecurity risk management activities and outcomes are included in enterprise risk management processes	3	present	90%	The CISO reports the Group's cyber risk posture to the Board Risk Committee on a quarterly basis.	While reporting to the Board Risk Committee is established, there is no explicit documentation of standardized criteria for escalating cybersecurity risks within the broader enterprise risk management framework.	Define and document clear, quantitative escalation thresholds for cybersecurity risks to ensure consistent integration into the enterprise risk management framework.
GV.RM-04 — Strategic direction that describes appropriate risk response options is established and communicated	2	partial	85%	The organization has a Vendor Risk Management Policy to oversee third-party platform risks and uses an internal vulnerability management SLA for remediation.	There is no documented strategic direction specifying criteria for accepting, avoiding, or transferring cybersecurity risks (such as cyber insurance) across different data classifications.	Establish and document a comprehensive risk response strategy that defines criteria for risk acceptance, avoidance, and transfer (including cyber insurance) across different data classifications.
GV.RM-05 — Lines of communication across the organization are established for cybersecurity risks, including risks from suppliers and other third parties	3	present	90%	The CISO reports quarterly to the Board Risk Committee, and third-party risks are communicated and escalated via the Vendor Risk Management Policy.	Although lines of communication exist for senior leadership and third parties, there is limited evidence of a structured, cross-departmental communication plan for cybersecurity risks among non-technical business units.	Formalize a cross-departmental communication framework that details how all business units (e.g., legal, HR, operations) communicate and collaborate on cybersecurity risks.
GV.RM-06 — A standardized method for calculating, documenting, categorizing, and prioritizing cybersecurity risks is established and communicated	2	partial	85%	The organization uses CVSS severity to prioritize vulnerability remediation under an internal SLA, but lacks a broader standardized risk calculation methodology.	There is no evidence of a standardized risk calculation methodology (e.g., risk formulas or a centralized risk register) used to categorize and prioritize all cybersecurity risks across the organization.	Implement a standardized risk assessment methodology (such as NIST SP 800-30 or FAIR) and establish a centralized cybersecurity risk register to document, categorize, and prioritize all identified risks.

GV.RM — Risk Management Strategy

confidence 85%

CMMI 2

Northwind Financial has established basic governance structures, including a Group Risk Management Strategy and quarterly reporting to the Board Risk Committee by the CISO. However, the organization lacks formalized, cybersecurity-specific risk appetite and tolerance statements, and communication of strategic context is currently ad-hoc via email. Standardized risk calculation is limited to CVSS-based vulnerability prioritization, and positive risks are not characterized or discussed.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
GV.RM-07 — Strategic opportunities (i.e., positive risks) are characterized and are included in organizational cybersecurity risk discussions	1	absent	90%	The provided documentation and interview answers contain no mention of identifying, characterizing, or discussing strategic opportunities or positive risks.	The organization completely lacks a process or framework for identifying and incorporating positive risks or strategic opportunities into cybersecurity risk discussions.	Define guidance and methods (such as SWOT analysis) to identify positive risks and strategic opportunities, and include them in regular cybersecurity risk discussions with senior leadership.

GOVERN · TIER 2

GV.RR — Roles, Responsibilities, and Authorities

confidence 90%

CMMI 3

The organization demonstrates a strong, formalized governance structure for key cybersecurity roles, driven by regulatory compliance under the Senior Managers & Certification Regime (SM&CR). The CISO holds a designated Senior Manager Function (SMF24) with personal statutory accountability, and their performance is reviewed annually by the Board. However, while executive roles and operational responsibilities (e.g., IT Director, Managed SOC) are well-defined, there is a lack of quantitative KPIs for non-executive roles and limited evidence of cybersecurity integration into general HR practices (e.g., onboarding/offboarding and background checks).

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
GV.RR-01 — Organizational leadership is responsible and accountable for cybersecurity risk and fosters a culture that is risk-aware, ethical, and continually improving	4	present	90%	The Board of Directors approves the CISO's Statement of Responsibilities and conducts an annual fitness and propriety assessment of the CISO based on performance and incident outcomes (Chunks 4, 6).	While annual performance reviews and culture surveys are conducted, there is no evidence of formal, quantitative KRIs/KPIs specifically tracking leadership's own strategic cybersecurity performance.	Establish specific, quantifiable KPIs for leadership's oversight of the cybersecurity strategy, and integrate these metrics into the annual Board-level reporting to drive continuous improvement.
GV.RR-02 — Roles, responsibilities, and authorities related to cybersecurity risk management are established, communicated, understood, and enforced	4	present	90%	Roles and responsibilities for the CISO, IT Director, and Compliance Officer are formally documented in policies and a regulatory SM&CR Statement of Responsibilities signed by the CISO and CEO (Chunks 1, 2, 6, 7). The CISO's performance is reviewed annually by the Board, and quarterly outcomes reporting is conducted (Chunks 2, 4).	The evidence does not show defined, quantitative KPIs (such as policy exception rates or remediation times) for non-executive roles with security responsibilities (e.g., the IT Director or Compliance Officer).	Define and document specific, measurable KPIs (e.g., patch latency or policy exception rates) for all key roles with cybersecurity responsibilities, including the IT Director, and track these quarterly.
GV.RR-03 — Adequate resources are allocated commensurate with the cybersecurity risk strategy, roles, responsibilities, and policies	3	partial	80%	The organization has allocated resources for a dedicated CISO, an IT Director, a Compliance Officer, and an external Managed SIEM/SOC Provider to support security operations (Chunks 1, 2, 9).	There is no documented evidence of a formal, periodic management review process to assess resource adequacy or to align resource allocation directly with risk tolerance and strategy.	Implement a formal annual resource review process led by the CISO and Board to evaluate whether current staffing, funding, and tooling are adequate to meet the cybersecurity strategy and risk tolerance.
GV.RR-04 — Cybersecurity is included in human resources practices	2	partial	80%	The organization integrates cybersecurity accountability into HR/compliance practices for senior roles through the annual SM&CR fitness and propriety assessment for the CISO (Chunk 4).	There is no evidence of cybersecurity integration into general HR practices, such as background checks for sensitive roles, onboarding/offboarding procedures, or general personnel screening.	Formally integrate cybersecurity requirements into standard HR processes, including mandatory background checks for sensitive roles and structured onboarding/offboarding checklists.

GOVERN · TIER 2

GV.PO — Policy

confidence 85%

CMMI 3

Northwind Financial has established formal, version-controlled policies for specific domains like logging and secure software development, which include defined review cadences and triggers for technology or regulatory changes. However, the organization lacks an overarching risk management policy, and communication of organizational context to risk decision-makers remains informal (via email). Additionally, there is no evidence of a formal policy exception process or systematic compliance tracking.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
GV.PO-01 — Policy for managing cybersecurity risks is established based on organizational context, cybersecurity strategy, and priorities and is communicated and enforced	2	partial	80%	Northwind Financial has established specific policies such as the Logging and Monitoring Standard and the Secure SDLC Policy, which are formally approved by leadership. However, communication of organizational context and strategy to risk decision-makers is handled informally via email by the IT Director's manager.	There is no evidence of an overarching risk management policy, and there is no formal mechanism or requirement for personnel to acknowledge receipt of policies upon hire or annually.	Develop and formally approve an overarching cybersecurity risk management policy that establishes management intent and direction. Implement a formal policy dissemination and annual acknowledgment process for all personnel.
GV.PO-02 — Policy for managing cybersecurity risks is reviewed, updated, communicated, and enforced to reflect changes in requirements, threats, technology, and organizational mission	3	present	85%	The Logging and Monitoring Standard and Secure SDLC Policy define clear review cadences (annual and biennial, respectively) and specify triggers for out-of-cycle reviews, such as material changes in technology, threats, or regulatory requirements.	While review cadences and triggers are defined, there is no evidence that policy compliance is actively measured or that policy updates are systematically driven by measured control effectiveness or exception rates.	Establish a formal process to track policy compliance and exceptions, and use this data alongside incident post-mortems to drive policy updates.

GOVERN · TIER 2

GV.OV — Oversight

confidence 90%

CMMI 3

The organization has established a formal oversight structure with defined reporting lines to the Board Risk Committee on a quarterly cadence. Standardized metrics, including detection performance and culture survey results, are regularly communicated to senior leadership, and policies are reviewed annually. However, the oversight process lacks trend analysis against defined targets and a closed-loop mechanism to systematically feed oversight findings back into strategy and resourcing adjustments.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
GV.OV-01 — Cybersecurity risk management strategy outcomes are reviewed to inform and adjust strategy and direction	3	partial	90%	The CISO's accountability and risk management outcomes are reported quarterly to the Board Risk Committee, and the CISO's performance is reviewed annually by the Board based on incident outcomes and committee feedback.	There is no documented process or evidence showing that the Board or leadership explicitly measures how well the risk strategy helps achieve organizational objectives or adjusts strategies that impede operations.	Establish a formal process during the quarterly Board Risk Committee reviews to evaluate whether the current risk strategy is supporting or impeding business operations and innovation, and document any resulting strategic adjustments.
GV.OV-02 — The cybersecurity risk management strategy is reviewed and adjusted to ensure coverage of organizational requirements and risks	3	partial	90%	The CISO holds overall responsibility for the Group's risk management framework, and the security standards are reviewed annually or following material changes in the technology estate or threat landscape.	The evidence does not show a formal mechanism for reviewing audit findings or compliance reports specifically to adjust the cybersecurity strategy's coverage of organizational requirements.	Integrate compliance and audit findings systematically into the annual strategy review process to ensure the cybersecurity strategy is adjusted to cover all evolving regulatory and organizational requirements.
GV.OV-03 — Organizational cybersecurity risk management performance is evaluated and reviewed for adjustments needed	3	present	90%	Cybersecurity performance metrics, including detection use case performance, triage times, and culture survey results, are collected quarterly and reported to the CISO and the Board Risk Committee.	While metrics are reported quarterly, they are presented as point-in-time snapshots without formal trend analysis over time or comparison against defined targets/thresholds to trigger resourcing adjustments.	Define specific performance targets and thresholds for the reported metrics (e.g., target mean time to triage) and include trend analysis in the quarterly Board reports to enable proactive resourcing decisions.

GOVERN · TIER 2

GV.SC — Cybersecurity Supply Chain Risk Management

confidence 85%

CMMI 3

Northwind Financial has established a documented Vendor Risk Management Policy and a Secure SDLC Policy that outline roles and responsibilities for third-party oversight, particularly for Critical-tier suppliers. However, the program lacks active, independent verification of vendor security postures, relying instead on self-reported quarterly security reports. Furthermore, critical gaps exist in integrating suppliers into incident response planning and establishing formal offboarding procedures.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
GV.SC-01 — A cybersecurity supply chain risk management program, strategy, objectives, policies, and processes are established and agreed to by organizational stakeholders	3	partial	80%	Northwind Financial has established a Vendor Risk Management Policy and a Secure SDLC Policy that govern third-party platform oversight and Critical-tier supplier reviews.	There is no evidence of a comprehensive, standalone supply chain risk management strategy or a cross-organizational alignment mechanism.	Formally document a cybersecurity supply chain risk management strategy and establish a cross-functional steering committee to align objectives across IT, security, legal, and procurement.
GV.SC-02 — Cybersecurity roles and responsibilities for suppliers, customers, and partners are established, communicated, and coordinated internally and externally	3	partial	85%	The Secure SDLC Policy documents roles for the CISO, IT Director, and Compliance Officer regarding third-party SDLC oversight and Critical-tier supplier oversight.	The organization lacks documented responsibility matrices (e.g., RACI) and formal rules for information sharing and reporting processes with suppliers.	Create a formal responsibility matrix (RACI) for supply chain risk management activities and establish clear protocols for information sharing with suppliers.
GV.SC-03 — Cybersecurity supply chain risk management is integrated into cybersecurity and enterprise risk management, risk assessment, and improvement processes	3	partial	80%	Third-party SDLC oversight outcomes are reviewed as part of vendor risk reporting, and the CISO is responsible for reporting the Group's cyber risk posture to the Board Risk Committee.	There is no evidence of integrated control sets that combine internal cybersecurity controls with supply chain risk management controls.	Integrate supply chain risk assessments into the broader Enterprise Risk Management (ERM) framework and establish a unified control set covering both internal and third-party risks.
GV.SC-04 — Suppliers are known and prioritized by criticality	3	partial	85%	The organization utilizes a 'Critical-tier' classification for supplier oversight under its Vendor Risk Management Policy.	The specific criteria used to define criticality tiers and the completeness of the supplier inventory are not fully detailed in the provided evidence.	Document the specific criteria used for supplier criticality tiering and ensure the vendor inventory is comprehensively maintained and updated regularly.
GV.SC-05 — Requirements to address cybersecurity risks in supply chains are established, prioritized, and integrated into contracts and other types of agreements with suppliers and other relevant third parties	3	partial	80%	The organization monitors third-party secure development practices and logging coverage through quarterly security reports under the Vendor Risk Management Policy.	There is no evidence of standard contractual clauses requiring suppliers to provide Software Bills of Materials (SBOMs) or allowing Northwind Financial to independently verify compliance.	Develop standard cybersecurity contract templates that include specific requirements for SBOMs, vulnerability disclosure, and right-to-audit clauses.
GV.SC-06 — Planning and due diligence are performed to reduce risks before entering into formal supplier or other third-party relationships	3	partial	80%	The Compliance Officer reviews vendor-disclosed secure development practices for Critical-tier suppliers under the Vendor Risk Management Policy.	The evidence does not detail a standardized pre-onboarding due diligence process or risk assessment templates applied consistently across all prospective vendors before contracts are signed.	Establish a standardized pre-contract due diligence process with specific questionnaires and technical assessments tailored to the prospective vendor's risk tier.

GV.SC — Cybersecurity Supply Chain Risk Management

confidence 85%

CMMI 3

Northwind Financial has established a documented Vendor Risk Management Policy and a Secure SDLC Policy that outline roles and responsibilities for third-party oversight, particularly for Critical-tier suppliers. However, the program lacks active, independent verification of vendor security postures, relying instead on self-reported quarterly security reports. Furthermore, critical gaps exist in integrating suppliers into incident response planning and establishing formal offboarding procedures.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
GV.SC-07 — The risks posed by a supplier, their products and services, and other third parties are understood, recorded, prioritized, assessed, responded to, and monitored over the course of the relationship	3	partial	85%	Northwind Financial monitors its SaaS platform vendor's secure development and logging practices through quarterly security reports.	The organization relies entirely on vendor-provided quarterly reports and does not independently verify compliance or perform active, ongoing risk monitoring.	Implement a continuous monitoring mechanism for critical suppliers, such as third-party security rating services, and establish a process to track and verify the remediation of vendor-identified gaps.
GV.SC-08 — Relevant suppliers and other third parties are included in incident planning, response, and recovery activities	1	absent	80%	There is no evidence in the provided documentation indicating that suppliers or third parties are integrated into Northwind Financial's incident response planning, exercises, or recovery activities.	Critical suppliers are not included in incident response playbooks, communication protocols, or tabletop exercises.	Update incident response plans to define communication protocols with critical vendors during an incident, and include key third-party representatives in annual incident response tabletop exercises.
GV.SC-09 — Supply chain security practices are integrated into cybersecurity and enterprise risk management programs, and their performance is monitored throughout the technology product and service life cycle	3	partial	80%	The Secure SDLC Policy covers oversight arrangements for secure development practices applied by third-party platform vendors, including the SaaS platform vendor.	There is no evidence of policies requiring provenance records for acquired technology products or verification of authenticity for hardware/software upgrades.	Establish policies and procedures requiring provenance verification for all acquired technology products and software updates before deployment.
GV.SC-10 — Cybersecurity supply chain risk management plans include provisions for activities that occur after the conclusion of a partnership or service agreement	1	absent	80%	The provided documentation does not contain provisions or procedures for cybersecurity activities following the termination or conclusion of a supplier relationship.	There is a lack of documented processes for deactivating vendor access, returning/disposing of data, and managing data leakage risks upon contract termination.	Develop a formal vendor offboarding checklist that includes prompt deactivation of logical access, secure return or destruction of data, and formal sign-off from the compliance team.

IDENTIFY · TIER 1

ID.AM — Asset Management

confidence 80%

CMMI 1

The organization's asset management practices are at an initial stage (CMMI Level 1). While there are established processes for logging, monitoring, and secure software development (Chunk [5], [12]), there is no evidence of centralized inventories for hardware, software, or data assets. Supplier services are partially tracked under a Vendor Risk Management Policy (Chunk [7]), but a comprehensive asset management framework with prioritization and lifecycle controls is currently absent.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
ID.AM-01 — Inventories of hardware managed by the organization are maintained	1	absent	80%	The provided evidence does not mention a hardware asset inventory. It only notes that endpoints and network devices are configured to generate logs and are monitored via EDR (CrowdStrike Falcon) (Chunk [5], [6]).	There is no documented central hardware inventory or automated discovery process to maintain a baseline of managed hardware assets.	Establish a centralized hardware asset inventory that covers all IT, IoT, and mobile devices, and implement automated network scanning to discover and register new hardware.
ID.AM-02 — Inventories of software, services, and systems managed by the organization are maintained	1	absent	80%	The evidence does not describe any software, system, or service inventory. It only mentions that in-scope systems are configured for log generation (Chunk [3], [5]).	The organization lacks a centralized inventory of software, systems, and services managed across the technology estate.	Implement a software asset management (SAM) tool or process to discover, catalog, and maintain an inventory of all authorized software, systems, and services.
ID.AM-03 — Representations of the organization's authorized network communication and internal and external network data flows are maintained	1	absent	80%	There is no mention of network communication baselines, data flow diagrams, or documented network ports and protocols in the provided evidence.	The organization lacks documented representations of authorized network communications and internal/external data flows.	Develop and maintain network data flow diagrams and communication baselines, mapping internal and external data paths and authorized ports/protocols.
ID.AM-04 — Inventories of services provided by suppliers are maintained	2	partial	75%	The evidence mentions a Vendor Risk Management Policy and oversight of 'Critical-tier' suppliers, such as the SaaS general insurance platform vendor (Chunk [7], [11], [14]).	While critical-tier suppliers are monitored, there is no evidence of a comprehensive, centralized inventory of all external services and suppliers used by the organization.	Consolidate all third-party services (SaaS, PaaS, IaaS, and APIs) into a centralized supplier inventory managed under the Vendor Risk Management Policy, updating it systematically during onboarding.
ID.AM-05 — Assets are prioritized based on classification, criticality, resources, and impact on the mission	1	absent	80%	The evidence does not outline any asset prioritization or classification criteria, except for a reference to 'Critical-tier' suppliers (Chunk [7]).	There is no documented methodology or criteria for prioritizing hardware, software, or data assets based on criticality and mission impact.	Define and document asset classification and prioritization criteria based on business impact, and apply these tiers to all inventoried assets.
ID.AM-07 — Inventories of data and corresponding metadata for designated data types are maintained	1	absent	80%	The evidence mentions that production data is kept separate from non-production environments and masked/anonymized (Chunk [12]), but does not describe a data inventory or classification scheme.	The organization lacks a formal inventory of data assets, designated data types, and corresponding metadata or classification tags.	Establish a data classification policy, identify designated data types (e.g., PII, financial data), and implement data discovery tools to inventory and tag sensitive data assets.

ID.AM — Asset Management

confidence 80%

CMMI 1

The organization's asset management practices are at an initial stage (CMMI Level 1). While there are established processes for logging, monitoring, and secure software development (Chunk [5], [12]), there is no evidence of centralized inventories for hardware, software, or data assets. Supplier services are partially tracked under a Vendor Risk Management Policy (Chunk [7]), but a comprehensive asset management framework with prioritization and lifecycle controls is currently absent.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
ID.AM-08 — Systems, hardware, software, services, and data are managed throughout their life cycles	1	absent	80%	The evidence outlines secure development principles and testing/release management for software (Chunk [10], [12]), but does not address lifecycle management (e.g., decommissioning, secure disposal) for hardware, systems, or data.	There is no comprehensive lifecycle management process covering the procurement, deployment, decommissioning, and secure destruction of hardware, systems, and data.	Develop a comprehensive asset lifecycle management procedure that integrates security requirements from procurement through decommissioning, including secure hardware sanitization and data destruction.

IDENTIFY · TIER 1

ID.RA — Risk Assessment

confidence 85%

CMMI 2

Northwind Financial has established solid foundational elements for risk assessment, particularly in vulnerability scanning, change management, and critical supplier oversight. However, the organization lacks a centralized, standardized risk assessment methodology and risk register that consistently calculates threat likelihoods and impacts. Additionally, there is no formal process for receiving external vulnerability disclosures, placing the overall maturity at Level 2.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
ID.RA-01 — Vulnerabilities in assets are identified, validated, and recorded	3	present	90%	Vulnerability identification is performed through continuous automated scanning and an annual independent penetration test, with remediation tracked against CVSS severity SLAs (Chunk [4]). Security testing and vulnerability scanning are also performed prior to production release for internet-facing components (Chunk [19]).	There is no evidence that vulnerability data is integrated into a centralized, quantitative risk assessment methodology that covers all asset types (including physical facilities or non-internet-facing components) beyond IT systems.	Integrate vulnerability scan data directly into a centralized risk register and define risk assessment triggers for new asset classes or physical facilities.
ID.RA-02 — Cyber threat intelligence is received from information sharing forums and sources	2	partial	80%	Threat intelligence sources set out in the Vulnerability Management Standard are used quarterly to inform the tuning of the detection use case library (Chunk [1]).	There is no evidence of automated ingestion of threat intelligence feeds into security tools or active participation in information-sharing forums.	Establish formal subscriptions to threat intelligence feeds (e.g., ISACs) and configure security tools to automatically ingest and act upon these feeds.
ID.RA-03 — Internal and external threats to the organization are identified and recorded	2	partial	80%	The organization monitors for internal and external threat indicators (such as anomalous authentication and lateral movement) using EDR and continuous network monitoring (Chunk [1], Chunk [9]).	The organization lacks a formal, documented process to identify, model, and record specific internal and external threat actors and their TTPs in a centralized threat register.	Develop a formal threat modeling process (e.g., using STRIDE or MITRE ATT&CK) to systematically identify and record threat actors and scenarios relevant to the organization.
ID.RA-04 — Potential impacts and likelihoods of threats exploiting vulnerabilities are identified and recorded	2	partial	75%	The CISO is responsible for the Group's cybersecurity risk management framework and reporting risk posture to the Board Risk Committee (Chunk [8]), but specific methodologies for calculating likelihood and impact are not detailed.	There is no evidence of a standardized, documented methodology for scoring and recording the likelihood and impact of threat scenarios across the organization's business units.	Define and document a standard risk scoring rubric (e.g., 5x5 matrix for likelihood and impact) and apply it consistently to all identified risk scenarios in a centralized risk register.
ID.RA-05 — Threats, vulnerabilities, likelihoods, and impacts are used to understand inherent risk and inform risk response prioritization	2	partial	80%	Vulnerability remediation is prioritized based on CVSS severity SLAs (Chunk [4]), and the CISO manages the Group Risk Management Strategy (Chunk [8]).	The organization does not demonstrate a comprehensive process where threat, vulnerability, likelihood, and impact are combined to calculate inherent risk and drive broader cybersecurity resource allocation or investment decisions.	Establish a formal risk-based prioritization framework that goes beyond CVSS scores to incorporate business impact and threat likelihood when prioritizing risk responses and security investments.
ID.RA-06 — Risk responses are chosen, prioritized, planned, tracked, and communicated	2	partial	80%	Vulnerability remediation progress is tracked against SLAs and reported (Chunk [4]), and the CISO reports the risk posture to the Board Risk Committee (Chunk [8]).	There is no evidence of a centralized risk register that tracks formal risk treatment decisions (accept, mitigate, transfer, avoid) with named owners and status tracking for non-vulnerability risks.	Implement a centralized risk register that records formal risk treatment decisions, assigns named owners, and tracks remediation plans (such as POA&Ms) to completion.

ID.RA — Risk Assessment

confidence 85%

CMMI 2

Northwind Financial has established solid foundational elements for risk assessment, particularly in vulnerability scanning, change management, and critical supplier oversight. However, the organization lacks a centralized, standardized risk assessment methodology and risk register that consistently calculates threat likelihoods and impacts. Additionally, there is no formal process for receiving external vulnerability disclosures, placing the overall maturity at Level 2.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
ID.RA-07 — Changes and exceptions are managed, assessed for risk impact, recorded, and tracked	3	present	85%	Material changes and software releases are tested in non-production environments and formally assessed and approved through the Change Management Policy (Chunk [19]).	While change management is documented, there is no explicit evidence of a formal process for managing, risk-assessing, and periodically reviewing security policy exceptions.	Document and implement a formal security exception management process that requires risk assessment, formal approval, and periodic re-evaluation of accepted exceptions.
ID.RA-08 — Processes for receiving, analyzing, and responding to vulnerability disclosures are established	1	absent	85%	The evidence does not describe any process or policy for receiving, analyzing, or responding to vulnerability disclosures from external researchers or third parties.	The organization lacks a formal vulnerability disclosure policy (VDP) or process to handle external vulnerability reports.	Establish a formal vulnerability disclosure program, including a public-facing policy and internal procedures for triaging and remediating reported vulnerabilities.
ID.RA-09 — The authenticity and integrity of hardware and software are assessed prior to acquisition and use	2	partial	80%	The organization reviews vendor-disclosed secure development practices and quarterly security reports for its SaaS platform under the Vendor Risk Management Policy (Chunk [7], Chunk [10]).	There is no evidence of a formal process to assess the authenticity and integrity of hardware and software products prior to acquisition and deployment.	Define and implement a pre-acquisition assessment process that verifies the authenticity and integrity of hardware and software components before they are purchased or introduced into the environment.
ID.RA-10 — Critical suppliers are assessed prior to acquisition	3	present	85%	The Compliance Officer reviews vendor-disclosed secure development practices as part of Critical-tier supplier oversight under the Vendor Risk Management Policy (Chunk [10]).	While critical suppliers are assessed, there is no evidence that these assessments are integrated into a broader, continuous supply chain risk management program.	Standardize the pre-acquisition supplier risk assessment process across all tiers of suppliers and establish a cadence for periodic reassessment of existing critical suppliers.

IDENTIFY · TIER 1

ID.IM — Improvement

confidence 85%

CMMI 2

The organization has established basic operational improvement activities, such as quarterly tuning of detection use cases based on post-incident reviews and tracking vulnerability remediation against SLAs. However, it lacks a centralized process for tracking broader audit findings, does not conduct security exercises like tabletops, and lacks comprehensive, documented incident response and business continuity plans.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
ID.IM-01 — Improvements are identified from evaluations	2	partial	80%	The organization performs annual independent penetration testing and continuous automated scanning, with vulnerability remediation tracked against SLAs (Chunk 8). CISO accountability is also reviewed annually by the Board (Chunk 1).	There is no evidence of a centralized, documented process to capture, log, and track non-vulnerability improvement recommendations from audits or assessments to remediation.	Establish a centralized register for all audit and assessment findings, assigning owners and tracking remediation progress against defined timelines to move toward a Level 3 maturity.
ID.IM-02 — Improvements are identified from security tests and exercises, including those done in coordination with suppliers and relevant third parties	2	partial	85%	The organization conducts annual independent penetration testing (Chunk 8) and pre-release security testing for internet-facing components (Chunk 7).	The organization does not conduct tabletop exercises, simulations, or joint contingency exercises with critical suppliers to identify improvements.	Design and execute annual tabletop exercises involving key internal stakeholders and critical suppliers, documenting lessons learned to improve incident response and business continuity plans.
ID.IM-03 — Improvements are identified from execution of operational processes, procedures, and activities	3	present	85%	The use case library is reviewed and tuned quarterly using lessons from post-incident reviews (Chunk 4), and standards are reviewed annually or following material changes (Chunk 5). Operational metrics are tracked quarterly (Chunk 2).	While operational tuning is documented, there is no evidence of collaborative lessons-learned sessions conducted with suppliers.	Expand the operational review process to include formal, collaborative lessons-learned sessions with critical suppliers following major operational events or on an annual basis.
ID.IM-04 — Incident response plans and other cybersecurity plans that affect operations are established, communicated, maintained, and improved	2	partial	80%	The organization has a SOC Playbook, a Governance and Escalation Chart (Chunk 6), and a Vulnerability Management Standard (Chunk 8).	There is no evidence of comprehensive, documented incident response, business continuity, or disaster recovery plans that are reviewed and updated annually.	Formally document and establish comprehensive incident response and business continuity plans, ensuring they are reviewed annually, updated with lessons learned, and communicated to all responsible parties.

PROTECT · TIER 1

PR.AA — Identity Management, Authentication, and Access Control

confidence 85%

CMMI 2

Northwind Financial demonstrates basic elements of identity and access management, such as enforcing multi-factor authentication and quarterly access reviews specifically for Vantage Assure administrative and privileged access. Additionally, secrets and credentials are managed through an approved process, and continuous monitoring tracks anomalous authentication patterns. However, there is a lack of documented organization-wide processes for standard user identity lifecycles, identity proofing, single sign-on, and physical access controls, limiting the overall maturity to Level 2.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
PR.AA-01 — Identities and credentials for authorized users, services, and hardware are managed by the organization	2	partial	80%	Secrets, credentials, and encryption keys are managed through the Group's approved secrets management process.	There is no documented organization-wide process for managing the lifecycle (requesting, tracking, and revoking) of user identities and hardware devices.	Establish and document a formal, organization-wide identity management process that covers the request, approval, provisioning, and de-provisioning of user and device identities.
PR.AA-02 — Identities are proofed and bound to credentials based on the context of interactions	1	absent	90%	The provided documentation does not contain details regarding identity proofing or credential binding procedures.	There is no documented process or evidence of identity proofing at enrollment or policies prohibiting credential sharing.	Define and implement a formal identity proofing procedure for employees and contractors during onboarding, and establish a policy that strictly prohibits credential sharing.
PR.AA-03 — Users, services, and hardware are authenticated	2	partial	85%	MFA is enforced for Vantage Assure administrative and privileged access to infrastructure supporting the Northwind Financial tenancy.	There is no evidence of organization-wide MFA enforcement for standard users, remote access, or legacy systems, nor documented password strength policies.	Define an organization-wide authentication policy requiring MFA for all remote and standard user access, and establish minimum password strength requirements.
PR.AA-04 — Identity assertions are protected, conveyed, and verified	1	absent	90%	The provided documents do not mention single sign-on (SSO), federation, or the protection of identity assertions.	There is no documented standard or implementation for protecting and verifying identity assertions or SSO configurations.	Implement a standards-based Single Sign-On (SSO) solution to centralize and protect identity assertions across corporate and cloud applications.
PR.AA-05 — Access permissions, entitlements, and authorizations are defined in a policy, managed, enforced, and reviewed, and incorporate the principles of least privilege and separation of duties	2	partial	85%	Privileged access for Vantage Assure is reviewed quarterly, and least privilege is applied to code handling Group or customer data.	There is no evidence of scheduled, comprehensive access reviews for standard user accounts or a formalized role-based access control (RBAC) framework across the organization.	Establish a formal, scheduled access review process for all user accounts (not just privileged ones) and implement a role-based access control framework to enforce least privilege.
PR.AA-06 — Physical access to assets is managed, monitored, and enforced commensurate with risk	1	absent	90%	The provided documentation does not contain information regarding physical access controls, monitoring, or facility security.	There is a complete lack of documented policies or evidence regarding physical access management and monitoring.	Develop and document a physical security policy that outlines controls such as visitor escorts, badge access, and camera monitoring for facilities housing critical assets.

PROTECT · TIER 1

PR.AT — Awareness and Training

confidence 90%

CMMI 1

There is no evidence of a formal cybersecurity awareness or training program for general staff or specialized roles in the provided documentation. While the organization tracks security culture engagement via an annual survey, it lacks structured training curricula, completion tracking, and phishing simulations, placing it at Level 1.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
PR.AT-01 — Personnel are provided with awareness and training so that they possess the knowledge and skills to perform general tasks with cybersecurity risks in mind	1	absent	90%	The documentation does not outline any structured cybersecurity awareness training program, though it mentions that tone-from-the-top messaging is sent to all staff and tracked via an annual culture survey.	The organization lacks a formal, recurring security awareness training curriculum and systematic tracking of training completion for general staff.	Develop and implement a formal security awareness training program delivered to all staff on a recurring annual cycle, and introduce periodic phishing simulations to reinforce learning.
PR.AT-02 — Individuals in specialized roles are provided with awareness and training so that they possess the knowledge and skills to perform relevant tasks with cybersecurity risks in mind	1	absent	90%	No evidence of specialized or role-based cybersecurity training for technical staff, developers, or privileged users is present in the provided documentation.	There is no defined curriculum, training requirement, or refresh cadence for individuals in specialized or high-risk roles.	Identify key specialized roles (such as developers and system administrators) and establish a defined curriculum and annual refresh cadence for role-based cybersecurity training.

PROTECT · TIER 1

PR.DS — Data Security

confidence 70%

CMMI 1

The organization demonstrates basic data security controls in its software development lifecycle, specifically mandating the separation of production and non-production environments and requiring masking or anonymisation of production data before use in testing (PR.DS-02). However, there is a complete lack of documented evidence regarding data-at-rest protection (PR.DS-01), data-in-use protection (PR.DS-10), and backup management and testing (PR.DS-11). Consequently, data security practices are applied inconsistently and lack an organization-wide framework, placing the overall category at Level 1.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
PR.DS-01 — The confidentiality, integrity, and availability of data-at-rest are protected	1	absent	70%	The Secure SDLC Policy mentions that secrets, credentials, and encryption keys are managed through an approved secrets management process, but there is no evidence of policies or controls for data-at-rest encryption or removable media.	There is no documented policy or evidence of implementation for data-at-rest encryption, full disk encryption, or removable media restrictions across the estate.	Develop and document a formal data classification and handling policy that mandates encryption at rest for all systems and endpoints, and restrict the use of removable media.
PR.DS-02 — The confidentiality, integrity, and availability of data-in-transit are protected	2	partial	80%	The Secure SDLC Policy requires production and non-production environments to be kept separate and mandates masking or anonymisation before production data can be used in non-production environments.	There is no documented requirement or evidence of consistent network encryption (data-in-transit) or automated outbound email encryption based on data classification.	Establish formal requirements for encrypting data-in-transit across all networks and implement automated email encryption or blocking for sensitive outbound communications.
PR.DS-10 — The confidentiality, integrity, and availability of data-in-use are protected	1	absent	60%	There is no documented evidence or policy addressing the protection of data-in-use, such as removing confidential data from memory or isolating processes.	The organization lacks any formal policies, standards, or technical controls to protect data-in-use or clear sensitive data from memory when no longer needed.	Define standards for secure memory management and process isolation, particularly for applications handling sensitive customer or financial data.
PR.DS-11 — Backups of data are created, protected, maintained, and tested	1	absent	60%	The provided documentation does not contain any information regarding backup creation, protection, maintenance, or testing practices.	There is no evidence of a backup policy, backup schedules, offline/offsite storage, or annual restore testing.	Establish a comprehensive backup policy defining backup frequencies, encryption requirements for backup media, offline/offsite storage rules, and a schedule for annual restore testing.

PROTECT · TIER 1

PR.PS — Platform Security

confidence 85%

CMMI 2

Northwind Financial demonstrates established capabilities in secure software development (PR.PS-06) and centralized logging and continuous monitoring (PR.PS-04) through its Secure SDLC Policy and Managed SIEM/SOC partnership. However, there is a significant lack of documented evidence or formal standards for configuration management (PR.PS-01), patch and hardware lifecycle management (PR.PS-02, PR.PS-03), and unauthorized software prevention (PR.PS-05). This results in an inconsistent platform security posture that relies heavily on reactive measures in several key areas.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
PR.PS-01 — Configuration management practices are established and applied	1	absent	80%	The provided documentation does not contain details regarding configuration management practices, secure baselines, or monitoring for configuration drift.	There is an absence of documented secure baseline configurations and configuration drift monitoring across the estate.	Establish and document secure baseline configurations for major platform types (including legacy and cloud systems) and implement a process to monitor for configuration drift.
PR.PS-02 — Software is maintained, replaced, and removed commensurate with risk	1	absent	80%	The evidence mentions vulnerability scanning for internet-facing components prior to release, but does not document a formal patching standard, patch SLAs, or end-of-life software management.	The organization lacks a documented patch management standard with defined patch timeframes scaled by severity, as well as plans for software end-of-life maintenance.	Develop and document a comprehensive patch management standard that defines patch timeframes scaled by severity, and establish an inventory and lifecycle plan for end-of-life software.
PR.PS-03 — Hardware is maintained, replaced, and removed commensurate with risk	1	absent	90%	There is no evidence in the provided documents addressing hardware maintenance, replacement, end-of-life planning, or secure disposal.	The organization lacks documented policies or plans for hardware lifecycle management, obsolescence, and secure disposal.	Define and implement a hardware lifecycle management plan that addresses end-of-life support, obsolescence, and secure, auditable hardware disposal.
PR.PS-04 — Log records are generated and made available for continuous monitoring	3	partial	90%	Core banking and corporate infrastructure systems generate security logs forwarded to a Managed SIEM/SOC Provider, while SaaS platform logging is managed by the vendor and monitored via quarterly reports without independent verification.	The organization does not independently verify the logging coverage and retention practices of its SaaS platform vendor against its own standards.	Establish a process to periodically verify or audit SaaS platform logging coverage and integration to ensure alignment with internal logging standards.
PR.PS-05 — Installation and execution of unauthorized software are prevented	1	absent	85%	The provided documentation does not mention controls for preventing the installation or execution of unauthorized software, or the use of approved DNS services.	There is no documented standard or technical control (such as application whitelisting or DNS filtering) to prevent unauthorized software execution.	Implement technical controls such as application control/allowlisting and configure platforms to use approved DNS services that block malicious domains.
PR.PS-06 — Secure software development practices are integrated, and their performance is monitored throughout the software development life cycle	3	partial	95%	Northwind has a Secure SDLC Policy requiring peer reviews, dependency checks, and pre-release security testing, and monitors third-party vendor SDLC via quarterly reports. Static analysis is currently applied on a project-by-project basis rather than consistently across all projects.	Static analysis tooling and dependency scanning are not consistently applied across all in-house development projects.	Standardize and automate static application security testing (SAST) and dependency scanning across all in-house development pipelines as part of the CI/CD process.

PROTECT · TIER 1

PR.IR — Technology Infrastructure Resilience

confidence 75%

CMMI 2

The organization demonstrates basic resilience capabilities, including annual disaster recovery testing, platform availability tracking, and separation of production and non-production environments. However, there is no evidence of a documented resilience architecture, comprehensive network segmentation, environmental threat protections, or proactive capacity planning. Consequently, the organization meets Level 2 maturity for some subcategories but remains at Level 1 for others.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
PR.IR-01 — Networks and environments are protected from unauthorized logical access and usage	2	partial	70%	The organization separates production and non-production environments and data as part of its secure development principles (Chunk [5]). However, there is no evidence of comprehensive network segmentation or zero trust architecture across the wider estate.	There is no documented network segmentation architecture or principle applied consistently across the IT, IoT, or OT environments, nor endpoint health checks before production access.	Develop and document a formal network segmentation architecture based on trust boundaries, and implement logical segmentation across all environments (IT, corporate, and cloud).
PR.IR-02 — The organization's technology assets are protected from environmental threats	1	absent	80%	The provided documentation does not contain any evidence regarding physical environmental threat protections for technology assets or infrastructure.	There is a complete lack of documented environmental protection standards or requirements for internal facilities and third-party service providers.	Establish and document environmental protection requirements for all physical hosting locations and incorporate these requirements into service provider contracts.
PR.IR-03 — Mechanisms are implemented to achieve resilience requirements in normal and adverse situations	2	partial	80%	The organization conducts annual disaster recovery testing and tracks platform availability (Chunk [7]), with joint responsibility defined for technology resilience (Chunk [9]).	There is no evidence of a documented resilience architecture that systematically maps failover mechanisms to defined recovery time objectives (RTOs) or eliminates single points of failure.	Document a comprehensive resilience architecture that defines failover and redundancy designs for critical systems, and align DR testing directly with formally defined recovery objectives.
PR.IR-04 — Adequate resource capacity to ensure availability is maintained	1	absent	80%	The provided evidence does not mention capacity planning, resource monitoring, or forecasting activities.	The organization lacks a defined, scheduled capacity planning process and proactive monitoring of resource headroom.	Implement continuous monitoring of compute, storage, and bandwidth utilization, and establish a scheduled, forward-looking capacity planning exercise.

DETECT · TIER 3

DE.CM — Continuous Monitoring

confidence 90%

CMMI 3

Northwind Financial has established a robust, documented continuous monitoring capability operated by a Managed SIEM/SOC Provider, covering network, endpoint (CrowdStrike Falcon), and core banking infrastructure. While network, personnel, and computing environment monitoring are highly mature and actively measured (Level 4), significant gaps remain in physical environment monitoring (Level 1) and real-time visibility into external SaaS provider activities (Level 2).

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
DE.CM-01 — Networks and network services are monitored to find potentially adverse events	4	present	90%	Network monitoring is performed continuously by the Managed SIEM/SOC Provider against a defined library of detection use cases, with logs from network devices forwarded to a central logging platform.	To reach Level 5, the organization needs to incorporate findings from active red team or purple team exercises to continuously refine network detection use cases, and benchmark analyst workload.	Integrate red team and purple team simulation results into the quarterly use case tuning process to proactively identify and close network monitoring blind spots.
DE.CM-02 — The physical environment is monitored to find potentially adverse events	1	absent	90%	The provided documentation does not contain any evidence of physical environment monitoring, such as physical access control logs, visitor records, or security camera monitoring.	There is no structured or centralized monitoring of the physical environment, leaving a complete gap in visibility regarding physical access and tampering.	Establish basic physical security monitoring by collecting and reviewing logs from physical access control systems (e.g., badge readers) and security alarms, and define a process for triaging physical security alerts.
DE.CM-03 — Personnel activity and technology usage are monitored to find potentially adverse events	4	present	90%	Personnel activity and technology usage are monitored using CrowdStrike Falcon EDR across Corporate IT and core banking, with telemetry forwarded to the Managed SIEM/SOC and correlated with authentication logs.	To reach Level 5, the organization needs to demonstrate that personnel monitoring use cases are continuously refined using threat intelligence, insider threat scenarios, or red/purple team exercises, and benchmark analyst workload.	Incorporate insider threat scenarios and user behavior analytics (UBA) into the quarterly use case tuning cycle, leveraging correlated EDR and authentication logs to detect advanced insider threats.
DE.CM-06 — External service provider activities and services are monitored to find potentially adverse events	2	partial	85%	Northwind Financial relies on quarterly security reports from its SaaS general insurance platform vendor to gain visibility into logging and monitoring, without independent verification or real-time log integration into its SIEM.	The organization lacks real-time monitoring or centralized log ingestion for external service provider activities and cloud-based services, relying instead on retrospective quarterly reports.	Work with the SaaS platform vendor to ingest critical security logs (such as administrative access and configuration changes) directly into the Managed SIEM for real-time monitoring and correlation.
DE.CM-09 — Computing hardware and software, runtime environments, and their data are monitored to find potentially adverse events	4	present	90%	Computing hardware, software, and endpoints are monitored using CrowdStrike Falcon EDR and centralized log collection across core banking and corporate infrastructure, with active tracking of triage times and use case tuning.	To reach Level 5, the organization should integrate automated configuration drift monitoring and hardware/software tampering detection into the continuous monitoring scope, and refine these detections using threat intelligence.	Implement automated monitoring for software configuration deviations from security baselines and integrate these alerts into the Managed SIEM for real-time triage.

DETECT · TIER 3

DE.AE — Adverse Event Analysis

confidence 88%

CMMI 4

Northwind Financial demonstrates a strong Level 4 maturity for Adverse Event Analysis (DE.AE). The organization utilizes a Managed SIEM/SOC Provider to continuously monitor and correlate logs from multiple sources (including CrowdStrike Falcon EDR, Active Directory, and network devices) against a library of 42 detection use cases. Performance metrics, such as mean time to triage (~35 minutes) and the alert-to-confirmed-incident ratio, are tracked quarterly and reported to the CISO and Board Risk Committee to drive quarterly use case tuning.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
DE.AE-02 — Potentially adverse events are analyzed to better understand associated activities	4	present	90%	The Managed SIEM/SOC Provider continuously monitors log events against a defined library of 42 detection use cases and performs first-line alert triage in line with the SOC Playbook.	To reach Level 5, the organization should demonstrate continuous, automated feedback loops from incident response outcomes and red team findings directly into real-time playbook and correlation rule updates, rather than relying primarily on quarterly scheduled reviews.	Establish a formal, immediate feedback loop where lessons learned from every declared incident are directly translated into SIEM correlation rule updates within a set SLA, rather than waiting for the quarterly tuning cycle.
DE.AE-03 — Information is correlated from multiple sources	4	present	90%	Logs from servers, network devices, Active Directory, and CrowdStrike Falcon EDR telemetry are forwarded to a central logging platform operated by the Managed SIEM/SOC Provider for aggregation and correlation.	While correlation is performed across multiple sources and tuned quarterly, there is no evidence of automated, real-time correlation adjustments or benchmarking of correlation accuracy metrics (such as false positive rates per correlation rule) against industry standards.	Implement automated tuning of correlation rules based on machine learning or automated false-positive feedback loops, and track specific false-positive rates per correlation rule to optimize the SIEM.
DE.AE-04 — The estimated impact and scope of adverse events are understood	3	partial	80%	Alerts are triaged by the Managed SIEM/SOC Provider in line with the SOC Playbook, and escalated according to assessed severity levels (Critical/High) using a defined escalation path.	There is no explicit evidence showing how the estimated impact and scope (e.g., affected assets, user accounts, data sensitivity) are systematically calculated or documented during triage, or how these estimates are measured for accuracy.	Define clear, documented guidelines within the SOC Playbook for calculating the business impact and technical scope of an event (e.g., based on asset criticality and data classification) and track the accuracy of these initial estimates post-incident.
DE.AE-06 — Information on adverse events is provided to authorized staff and tools	4	present	85%	Alerts are triaged by the Managed SIEM/SOC Provider and routed to the escalation path according to severity, with performance metrics (like mean time to triage) reported quarterly to the CISO and Board Risk Committee.	While triage times are tracked and reported, there is no evidence of automated ticketing integration (e.g., bi-directional sync between SIEM and IT service management tools) or quality reviews of the escalation decisions to ensure consistency across different analysts.	Integrate the Managed SIEM platform directly with the internal ticketing system to automate ticket creation and routing, and establish a periodic quality review process for escalation decisions.
DE.AE-07 — Cyber threat intelligence and other contextual information are integrated into the analysis	3	partial	85%	Threat intelligence sources and lessons from post-incident reviews are used to inform the quarterly review and tuning of the detection use case library.	The integration of threat intelligence appears to be a periodic (quarterly) manual tuning process rather than a real-time, automated ingestion of threat feeds into the SIEM to enrich active alerts.	Configure the central logging platform/SIEM to ingest automated, real-time cyber threat intelligence (CTI) feeds to dynamically enrich and correlate incoming log events.
DE.AE-08 — Incidents are declared when adverse events meet the defined incident criteria	4	present	85%	Alerts are triaged and escalated according to assessed severity, and the alert-to-confirmed-incident ratio is tracked quarterly and reviewed to tune the detection use cases.	There is no evidence of formal, periodic quality reviews of escalation decisions (e.g., auditing false negatives or missed escalations) to ensure consistency across analysts.	Implement a formal quality assurance process where a sample of closed-as-benign alerts and escalated incidents are audited monthly to verify that incident declaration criteria are applied consistently.

RESPOND · TIER 1

RS.MA — Incident Management

confidence 85%

CMMI 2

Northwind Financial has established basic incident triage and escalation mechanisms through its Managed SIEM/SOC Provider, with triage performance metrics tracked quarterly. However, the organization lacks a comprehensive, formalized Incident Response Plan, and there is no evidence of documented incident categorization, prioritization matrices, or recovery initiation criteria.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
RS.MA-01 — The incident response plan is executed in coordination with relevant third parties once an incident is declared	2	partial	80%	The Managed SIEM/SOC Provider performs first-line alert triage and routes confirmed alerts to the escalation path.	There is no evidence of a comprehensive incident response plan that coordinates with other third parties or integrates with business continuity/disaster recovery plans.	Formally document and integrate the Managed SIEM/SOC Provider's playbook with an internal Incident Response Plan that outlines coordination with other key third parties and business continuity plans.
RS.MA-02 — Incident reports are triaged and validated	3	present	85%	Alerts are triaged by the Managed SIEM/SOC Provider in line with the SOC Playbook, and mean time to triage is tracked quarterly.	While triage is performed and measured, there is no evidence of formal testing of the triage process through live exercises or tabletop simulations.	Conduct annual tabletop exercises to test the triage and validation process under simulated incident scenarios, updating the SOC Playbook based on findings.
RS.MA-03 — Incidents are categorized and prioritized	2	partial	80%	Alerts are routed according to assessed severity, but detailed categorization and prioritization strategies are not documented in the provided evidence.	The organization lacks documented criteria for categorizing incidents by type (e.g., ransomware, DDoS) and prioritizing them based on business impact.	Define and document specific incident categorization and prioritization matrices within the incident response plan, aligning them with business impact assessments.
RS.MA-04 — Incidents are escalated or elevated as needed	2	partial	80%	Confirmed alerts are routed into the Governance and Escalation Chart's escalation path according to assessed severity.	The escalation path is mentioned, but there is no evidence of defined escalation timeframes or formal tracking of escalation performance against targets.	Formalize the Governance and Escalation Chart into a documented procedure with specific, SLA-backed escalation timeframes for each severity level.
RS.MA-05 — The criteria for initiating incident recovery are applied	1	absent	85%	The provided evidence does not mention criteria or processes for initiating incident recovery.	There is a complete lack of documented criteria or authority definitions for transitioning from incident response to incident recovery.	Establish and document clear criteria and decision-making authorities for initiating incident recovery, taking operational disruption into account.

RESPOND · TIER 1

RS.AN — Incident Analysis

confidence 80%

CMMI 1

While Northwind Financial has established centralized log collection and continuous monitoring via a Managed SIEM/SOC Provider, it lacks formal, documented procedures for incident investigation, root-cause analysis, and forensic evidence handling. There is no evidence of a structured root-cause methodology, immutable recording of responder actions, or formal processes to estimate and validate incident magnitude. Consequently, the organization operates at a low maturity level, relying primarily on the Managed SIEM/SOC's operational capabilities rather than defined internal investigation standards.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
RS.AN-03 — Analysis is performed to establish what has taken place during an incident and the root cause of the incident	1	partial	80%	The Logging and Monitoring Standard notes that lessons identified through post-incident reviews are used to tune detection use cases quarterly.	There is no documented, structured root-cause analysis methodology (such as five-whys or fishbone) or formal process to establish the sequence of events and involved assets during an incident.	Develop and document a formal incident investigation procedure that mandates a structured root-cause analysis methodology (e.g., 5-Whys) and defines how to reconstruct the sequence of events.
RS.AN-06 — Actions performed during an investigation are recorded, and the records' integrity and provenance are preserved	1	absent	85%	The provided documentation does not contain any requirements or procedures for recording actions taken by incident responders or ensuring the immutability of investigation records.	There is no formal requirement or mechanism to record incident response actions or preserve the integrity and provenance of investigation logs and documentation.	Establish a standard operating procedure requiring all incident responders to log their actions in a centralized, tamper-evident ticketing or incident management system to ensure record integrity.
RS.AN-07 — Incident data and metadata are collected, and their integrity and provenance are preserved	2	partial	80%	Security-relevant logs and EDR telemetry are forwarded to a central logging platform operated by the Managed SIEM/SOC Provider to support investigations.	The organization lacks documented evidence-handling and chain-of-custody procedures to safeguard the integrity and provenance of collected incident data and metadata during formal investigations.	Define and document formal evidence-handling and chain-of-custody procedures, particularly for incidents that may require legal or regulatory escalation, to ensure data integrity is legally defensible.
RS.AN-08 — An incident's magnitude is estimated and validated	1	absent	85%	The provided documents do not outline any processes, tools, or responsibilities for estimating and validating the magnitude of an incident or proactively searching for indicators of compromise across other systems.	There is no documented process or tooling defined to estimate incident magnitude or systematically scan other potential targets for persistence or lateral movement.	Integrate magnitude estimation steps into the incident response playbooks, including procedures to run automated scans (e.g., EDR sweeps) across the estate to identify lateral movement or persistence.

RESPOND · TIER 1

RS.CO — Incident Response Reporting and Communication

confidence 85%

CMMI 1

The organization lacks a defined incident communication plan, with evidence only pointing to an internal 'Governance and Escalation Chart's escalation path' for triaged alerts (Chunk [6]). There is no documented process for notifying external stakeholders, assessing regulatory or legal obligations, or sharing incident information with partners, suppliers, or ISACs, placing the category at Level 1.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
RS.CO-02 — Internal and external stakeholders are notified of incidents	1	absent	85%	The evidence only mentions routing confirmed alerts into a 'Governance and Escalation Chart's escalation path' (Chunk [6]). There is no documented procedure or evidence of notifying internal or external stakeholders, customers, or regulatory bodies during an incident.	There is no defined communication plan or procedure for notifying internal and external stakeholders (such as customers, partners, and regulators) of incidents, nor is there a process for assessing regulatory or legal notification obligations.	Develop and document a formal incident communication plan that defines specific internal and external notification triggers, timelines, and channels, including a process for assessing regulatory and legal notification obligations.
RS.CO-03 — Information is shared with designated internal and external stakeholders	1	absent	85%	The provided documentation does not contain details on how incident information is shared with internal stakeholders (like HR or senior leadership) or external stakeholders (such as ISACs or suppliers) during an active incident.	The organization lacks defined protocols, templates, or agreements for sharing incident-related information, TTPs, or status updates with designated internal and external stakeholders.	Establish protocols and templates for sharing incident information, including regular status updates for senior leadership, coordination methods with critical suppliers, and voluntary sharing mechanisms with ISACs.

RESPOND · TIER 1

RS.MI — Incident Mitigation

confidence 75%

CMMI 1

While the organization has a Managed SIEM/SOC Provider and EDR tooling (CrowdStrike Falcon) in place for monitoring and triage, there is no documented evidence of formal containment or eradication playbooks, verification steps, or mitigation metrics. Consequently, incident mitigation practices are currently informal and improvised, aligning with CMMI Level 1.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
RS.MI-01 — Incidents are contained	1	partial	75%	The organization utilizes CrowdStrike Falcon EDR and a Managed SIEM/SOC Provider who triages alerts in line with a SOC Playbook.	There are no documented containment playbooks, defined containment actions, or verification steps to confirm that containment was successful.	Develop formal containment playbooks for common incident types that specify standard containment actions (e.g., host isolation via CrowdStrike Falcon) and require a verification step to confirm effectiveness.
RS.MI-02 — Incidents are eradicated	1	partial	75%	The organization has a Managed SIEM/SOC Provider and uses CrowdStrike Falcon EDR, but the provided documentation does not detail eradication procedures.	There is an absence of documented eradication playbooks, criteria for determining when eradication is complete, or formal verification checklists.	Define and document eradication procedures within incident response playbooks, outlining how threats are fully removed and establishing a formal process to verify eradication before proceeding to recovery.

RECOVER · TIER 1

RC.RP — Incident Recovery Plan Execution

confidence 85%

CMMI 1

The organization lacks documented evidence of a formal incident recovery plan, recovery prioritization criteria, or post-incident verification procedures. While an annual disaster recovery test is mentioned in the availability metrics, there is no evidence of structured recovery execution, backup integrity verification, or formal post-incident operational norms, placing the organization at CMMI Level 1.

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
RC.RP-01 — The recovery portion of the incident response plan is executed once initiated from the incident response process	1	absent	85%	There is no documented evidence of an incident recovery plan or its execution procedures in the provided documentation.	The organization lacks a formal incident recovery plan and defined procedures to execute recovery actions once initiated from the incident response process.	Develop a formal incident recovery plan that integrates with the incident response process and clearly outlines roles, responsibilities, and authorization requirements for recovery.
RC.RP-02 — Recovery actions are selected, scoped, prioritized, and performed	1	absent	85%	The provided documentation does not contain criteria or procedures for selecting, scoping, or prioritizing recovery actions.	There is no documented framework or criteria to prioritize recovery actions based on system criticality or organizational needs.	Establish and document a recovery prioritization matrix based on business impact analysis (BIA) to guide the scoping and selection of recovery actions during an incident.
RC.RP-03 — The integrity of backups and other restoration assets is verified before using them for restoration	1	absent	85%	There is no evidence showing that the organization verifies the integrity of backups or restoration assets before using them.	The organization lacks defined procedures to check backups for malware, corruption, or indicators of compromise prior to restoration.	Implement a formal verification process for backups, including automated integrity checks and scanning for indicators of compromise (IoCs) before restoration.
RC.RP-04 — Critical mission functions and cybersecurity risk management are considered to establish post-incident operational norms	1	absent	80%	While an annual disaster recovery test is noted in the availability metrics, there is no evidence of documented post-incident operational norms or coordination with system owners to validate restoration.	The organization does not have a documented process to align recovery order with critical mission functions or to monitor restored systems to establish post-incident operational norms.	Define post-incident operational norms and establish a formal validation process with system owners to confirm successful restoration and monitor performance.
RC.RP-05 — The integrity of restored assets is verified, systems and services are restored, and normal operating status is confirmed	1	absent	85%	There is no documented process for verifying the integrity of restored assets or confirming normal operating status before returning systems to production.	The organization lacks a verification step (such as configuration baseline checks or security scans) to ensure restored systems are clean and safe for production.	Develop a verification checklist that includes configuration baseline checks and vulnerability scans to confirm the integrity of restored assets before they are put back online.
RC.RP-06 — The end of incident recovery is declared based on criteria, and incident-related documentation is completed	1	absent	85%	The provided documentation does not outline criteria for declaring the end of incident recovery or requirements for completing post-incident documentation.	There is no formal process or criteria to officially declare the end of recovery or to mandate the creation of after-action reports.	Define clear criteria for declaring the end of incident recovery and establish a template and process for completing after-action reports and documenting lessons learned.

RECOVER · TIER 1

RC.CO — Incident Recovery Communication

confidence 90%

CMMI 1

There is no documented evidence or interview responses addressing incident recovery communication processes, templates, or stakeholder coordination. The provided documentation focuses primarily on logging, monitoring, and a high-level disaster recovery test date, leaving recovery communication practices unestablished (Level 1).

Subcategory	CMMI	Evidence	Confidence	Observations	Gap	Recommendation
RC.CO-03 — Recovery activities and progress in restoring operational capabilities are communicated to designated internal and external stakeholders	1	absent	90%	The provided documentation only mentions that a disaster recovery test was completed on 14 May 2026, but does not outline any processes for communicating recovery activities or progress to internal or external stakeholders.	The organization lacks a documented recovery communication plan specifying who receives recovery status updates, at what cadence, and through what channels.	Develop a basic recovery communication plan that outlines key internal and external stakeholders, and establish informal or formal protocols for updating them during recovery activities.
RC.CO-04 — Public updates on incident recovery are shared using approved methods and messaging	1	absent	90%	There is no mention of public updates, breach notification procedures, or messaging strategies for incident recovery in the provided documentation.	There is no plan, pre-prepared templates, or defined approval paths for managing public or customer-facing communication during recovery from a significant incident.	Draft initial public communication templates and define a clear approval path for public updates during incident recovery to avoid reactive drafting.

Appendix — Documents Provided

The evidence this assessment was based on. Only documents present when the assessment was dispatched are listed.

1. 17. Logging_Monitoring_Standard.docx
2. 27. Vendor_Security_Report.docx
3. 31. SMCR_Statement_of_Responsibilities.docx
4. 36. Secure_SDLC_Policy.docx

Session d3108484-494b-48a9-82b2-6bf4a9aaf399 · Run 07cf55ba-0e44-485a-bb6d-2041c2d0fe5a · Generated 2026-08-31 11:08 UTC